UNIVERSIDAD D SEVILLA

Tema 3. Confidencialidad de la Información (IV)
Protocolos Seguros

Dr. Rafael Martínez Gasca
Grupo de Investigación **Quivir**,
Tecnologías Inteligentes y de Seguridad de los Sistemas de Información
Departamento de Lenguajes y Sistemas Informáticos
Universidad de Sevilla

Indice

- Conceptos Fundamentales
- Requisitos de la seguridad de la información
- Implementación de los requisitos de Confidencialidad
  - Criptografía
    - Cifrado de clave simétrica
    - Cifrado de clave asimétrica
    - Protocolo de Reparto de Clave
    - Protocolo SSL/TLS, SSH y PGP
    - Protocolos WEP, WAP y WAP2
    - XML Encryption
  - Esteganografía

- Un mensaje de **correo electrónico tradicional (SMTP)** generalmente viaja por múltiples máquinas.
  - ***Cualquiera puede leer y guardar el mensaje para su uso posterior***, por lo que la Confidencialidad es inexistente.
  - Por ello se desarrollan sistemas de **correo electrónico seguro**: ***PGP, (PEM) y S/MIME*** basados en el ***sobre digital*****.**
  - En **otras** ocasiones, los usuarios requieren, además de Confidencialidad que **su correo vaya firmado.**

¿Cómo implementar el correo seguro?

Esquemas para proveer seguridad en los correos electrónicos:

- **PGP (Pretty Good Privacy):**
  - Desarrollado por Phil Zimmerman en 1991.
  - Provee Confidencialidad (cifra los correos) y autenticación (firma los correos).
  - La gestión de claves en PGP se basa en la confianza mutua.
  - Está disponible como software libre en múltiples plataformas.
    - OpenPGP Es el estándar aprobado por IETF interoperable con PGP.
    - **Existe una implementación gratuita de OpenPGP (llamada GPG) (GNU Privacy Guard RFC 4880)** ***http://www.gnupg.org*** ***GnuPG 2.1.2*** released (11/2/2015)

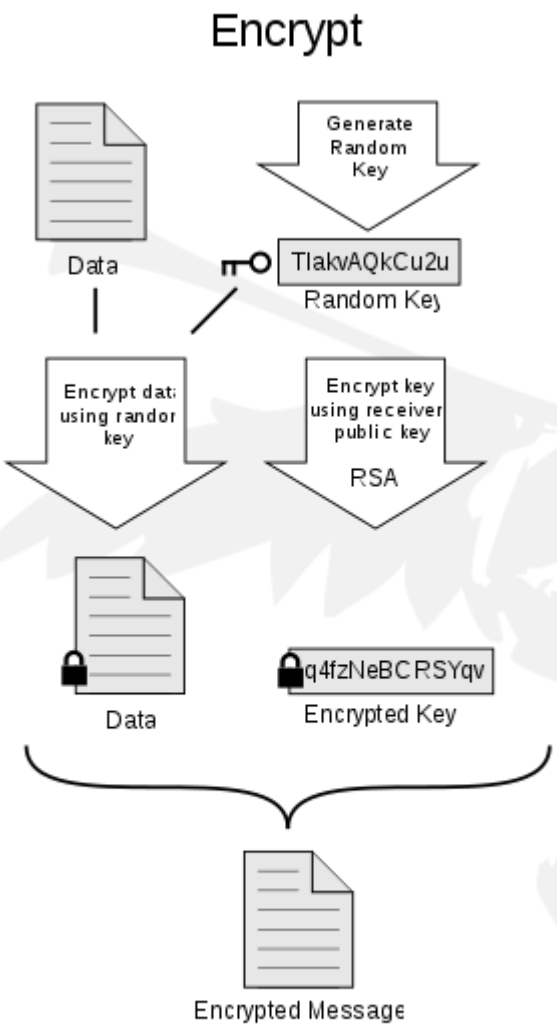
Esquemas para proveer seguridad en los correos electrónicos:

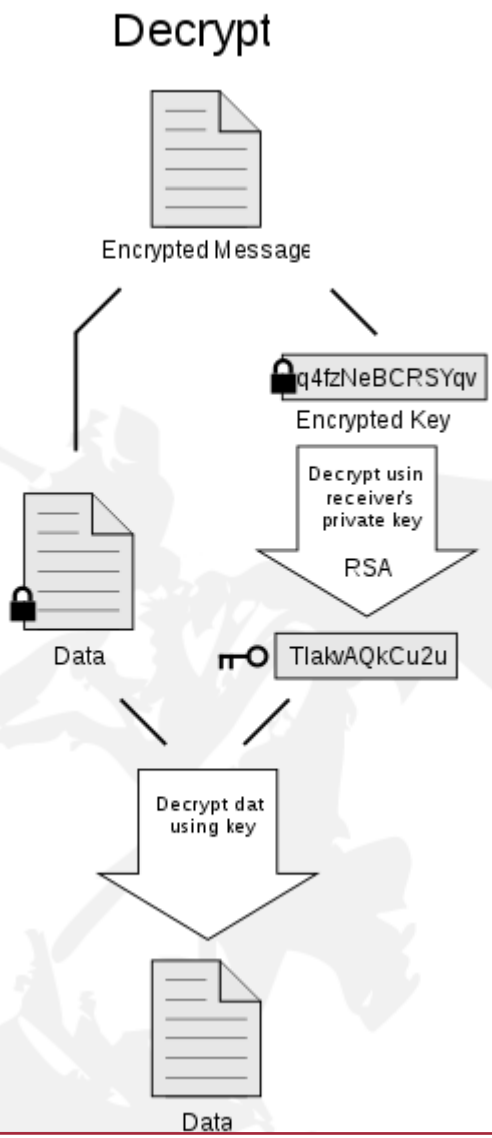
- **S/MIME (Secure/Multipurpose Internet Mail Extension):**
  - Utiliza certificados X509 y la infraestructura PKI.
  - Provee Confidencialidad (cifra los correos) y autenticación (firma los correos).
  - Version 2 de GnuPG también proporciona soporte para S/MIME.
- **PEM:** Estándar IETF propuesto para correo electrónico seguro. Resultó poco práctico al depender de un solo certificado raíz para la infraestructura de clave pública (PKI)

Implementación de la Confidencialidad.
Correo Electrónico. PGP

- Combina técnicas de criptografía asimétrica y simétrica
- El texto en claro es comprimido para fortalecer el cifrado
- PGP crea una clave de sesión secreta (un uso), basada en un número aleatorio para el algoritmo simétrico IDEA que cifra el texto comprimido
- La clave de sesión se cifra con la clave pública del receptor y se adjunta al texto cifrado
- El conjunto es enviado al receptor
- Para firmar el mensaje se genera un resumen y se crea la firma digital usando la clave privada del remitente (garantiza integridad y no repudio)

Implementación de la Confidencialidad.
Correo Electrónico. PGP



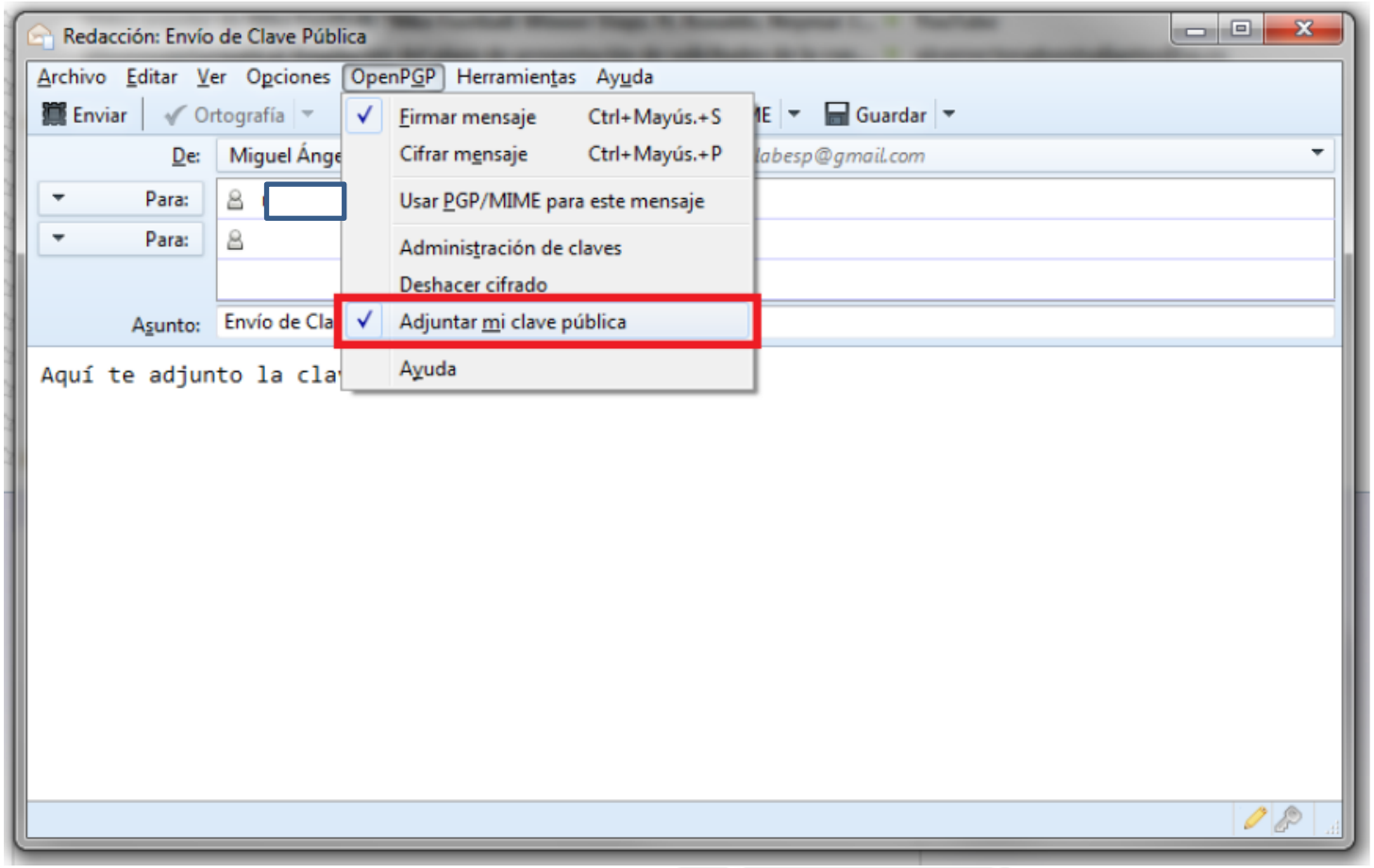


- El descifrado sigue el proceso inverso
  - **Cuando el receptor ecibe el mensaje**, descifra la **clave IDEA** usando su **clave RSA** privada. Con dicha clave puede descifrar el mensaje y descomprimirlo
  - Descifra el resumen usando la clave pública del emisor
  - Si concuerda con su propio cálculo del resumen sabe que el mensaje es correcto y que vino del emisor
- Este proceso sobre el correo, de cifrado con clave secreta y pública con compendios se conoce como ***envoltorio digital***
- **Si un usuario no dispusiera de clave o no tiene acceso al repositorio de claves no se envía el mensaje cifrado**

Implementación de la Confidencialidad.
Correo Electrónico. OpenPGP

- OpenPGP (RFC 4880) and OpenPGP/MIME (RFC 3156) según ITEF
  - Provee servicios de integridad y Confidencialidad para mensajes y ficheros de datos usando las tecnologías: firmas digitales, cifrado, compresión, conversión Radix-64
  - OpenPGP proporciona gestión de claves y servicios de certificado
- ***Enigmail*** es ***add-on*** para clientes de correo Mozilla Thunderbird permite recibir/enviar mensaje digitalmente firmados y/o cifrados (necesita GnuPGP que es una implementación de OpenPGP)
- **Mailvelope** para Firefox y Chrome

- Se deben intercambiar las claves públicas



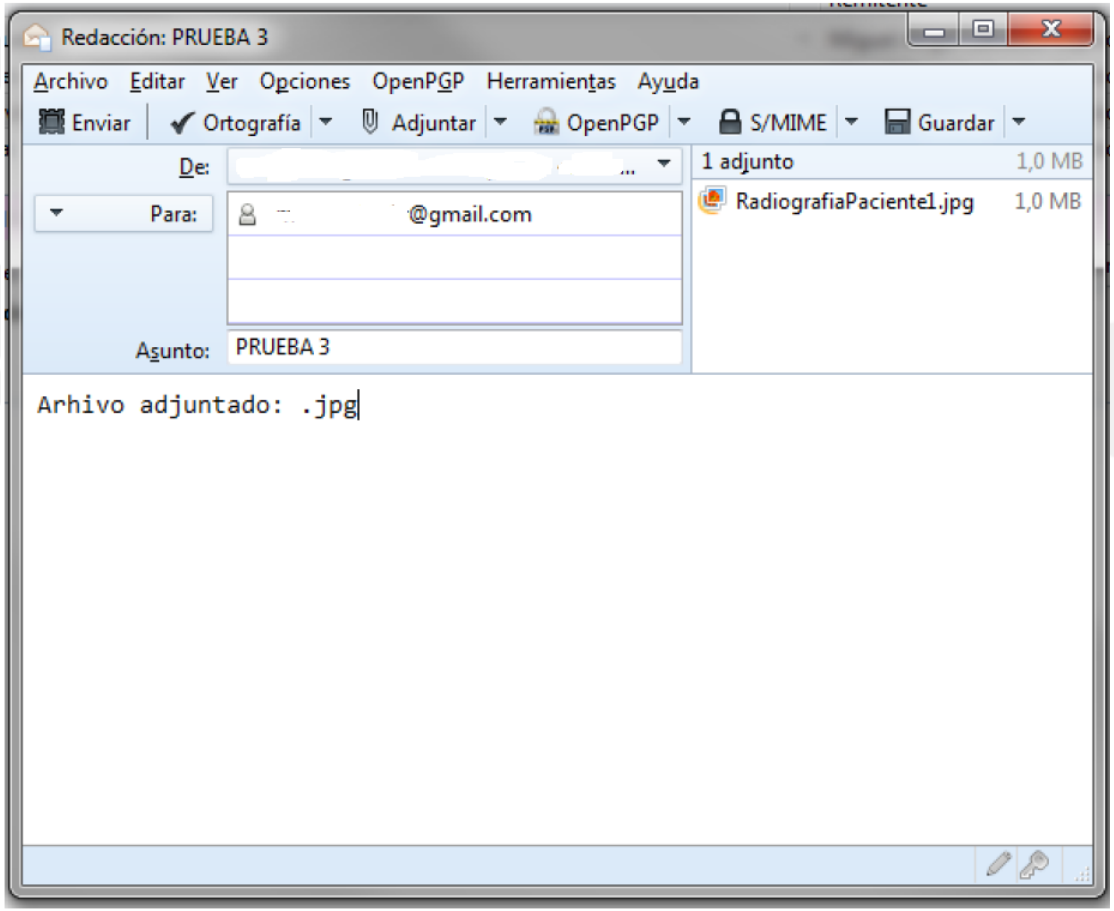
- Correo cifrado con PGP

Hola, Esto es una prueba de correo para comprobar el funcionamiento PGP

-----BEGIN PGP MESSAGE-----
Charset: ISO-8859-1
Version: GnuPG v2.0.22 (MingW32)
Comment: Using GnuPG with Thunderbird - http://www.enigmail.net/

hQIOA8VXTb/awpebEAf/eiJyVYD6ECpqNe4tW4Et7glNg1hJDrQf2k3teV6ZLvG5
+LvkfDxCzyo5XxRHEThZaBW+QMg+w9ia+zE2ZQkPJXifbi7bBe/SvNBDG5J250MV
MDsUbtf0Xjt6tnwv6b8wl3LRVMzfcS4SPj/TmfR9TycHjbsbeosKauD1ZtVgluvi
IWzWWW4N0A0C4klYJNO40KTB/oE0T2zDm3osTLIdKfJdeYRPNV6C6GfH2QEz3Y3q
vzGwYjm0GfAdtRXf9tjqS6DShbWq8d2fXTk2s4s3VX4Lj/X22C61eQjwA3xKq5M+
CqKXu8rO6XJnQ9f/kleMRuqpZqStwvMxUfRS9PjBRQgAotptf3MSM9FHeO47B8G2
leto/4jjrzowDlqlVtKZlHn1gRKWgZBBCiP/7b62zll2C84YxMpGem+PhJGy3yyK
TzLZ7E32ZQ5uOiTW+gnCpfdmwhdE1vULV63LhMb6Bmlyi8lJE6tN9UAvliZLe2pP
tqgiGFh7jmsKAyYsQDxvelSVQdlDzgGJz3SSdvKus9wm9DRpAlNUDpkJ1PdlRbwd
rDGQg/vb3VlJm2Nl2tttl0fdOxF/Rkw7Ecum7NEHnO5uUi5hpU98t1AsfSdRGSJU
5GGtMo4hScaAchc0Ui1Ei4LD3w1QTjHqX0par3nBoVe+vPDAuKDjtQlj00pZDmYY
ooUBDANgLY4AylGsfwEH/jyozfymqtrYS9D9u8VAEDMd71CPvJxnzd6E22LSlKyM
lPKvgr17U8R1Ak5pmg+Hgrry51UowfA5lHrEyWX4n4Kb5QDF1qdMpUPqfmBfZzlC
GZQmVTC6drThr5NPCobpDlKraUXafFlABFj8DQdpCrvQlBy1c6awL700C733p3xk
GqlUpSMGZa+cvjHtodiloHaokbLy2anBqZZVFgk+GIV5MokhzSGL3TohRNYf/ND/
cP7DG6fKT9c5UQ11nymkySqh2RBAZLklKLgngma5iywx7yZ50QuM0XVm1ZMub1hX
wDBA5M5bYEI5lGPrc5wM2jynsNmrU0s3/1r9Ua+Mi1vSwQoBSmOmlJKYZjiD0bqt
gWr7zXlX1/FrGXt22MrUUgnf+CKy+vszlgkiBVuUO8nlCPpFBAAbE8bDWuBUPVJ6
/WcN5tpx6Hn1bjiO1OT2KLCfGh841gm4ZjNpfwsvcuUUNrKg/K7hGJ20ODFo7W+5
3xEx+Db3XLaPJBelM8TDnfl0oOUSlLuGZrWh1vDM96VQosBLOhDKHqZKfmRNDfYt
aALiH84cm8nEyQISJDMYZ9qlMvyXLdPK62vniCiLxdGUYelKl0jYM1ZldpijzXcB
x+MujL/xLcEv4hooHsqMx3wASfBaFLXN+FQZbauA2bwHqFTTVjiS7u/fETfjaEza
426K1B66krnwAKfcrKCSoa58LFaBEykTleTrWmlx1vle0cKEqyUcRpQFisqqwNA/
IS3cP2CYIF6+4m0jgr2Zb089BoTMhW6UTwLIsKt0Bu/vl+HVP2muzbeDE+FVqNyH
NGNoEDb8QPyMPYJp2Hv2YDd715+spl3lbXWs97O6PgtB/iEOWvLStTllKK+F1BbR
Zl0+OfZyig1vjW0drwg2phutQ+uZ79talESvoQgKrKgXVGmMKz3/Umi2oXLWgXi3
A0G1/uRw+dWDTOMcTw==
=LpEv
-----END PGP MESSAGE-----

- Correo seguro con adjuntos



- Corrreo cifrado en editor

-----BEGIN PGP MESSAGE-----
Charset: ISO-8859-1
Version: GnuPG v2.0.22 (MingW32)
Comment: Using GnuPG with Thunderbird - http://www.enigmail.net/

hQIOA8VXTb/awpebEAf9HnLWoLAH1X3TlSdGs+0TyJgxaDq6aAgTY4nplrcTwD87
Gw0ulTVqsjVd1KCwN0eMx9T+urUMkzWZuzzkoK47z0SCn2XOltn0MS/3+Uj/V6nd
LX/RLEyWcQ/77eY1cESTeNYy0ly/M+s1jF0malCZescAj0dbw+vP2m5TlGuRVbrD
V9C7H1PyRhYq1iArddFWaf1xocdalcMFRuPaETPVUnqpk10PnaalMdhHMCnpQ1dT
KWhdB84vBUx2c7O78Pcdwzer2m+PWj+Ei31HqoImPfTRjH8fxA9dj8XblkEsBpx3
j3P59clEY6mbZ3iECje8BB1hn906XOR5icEDr06tUAf8DN4idN6BA9l8Nu3+19V8
9bd3M8+7wQkWAQOsBRh1f2seQyqkPdOmlFZGoEpXFNkWazBF3wET8p4NaEWJmuUa
nSpzfdAoFFbdNWC/EyxLYxMeMKaLlyPf8bvYD4qR0TMM1qatDv013pGOLGGbb1Ts
i4GYkyMHh8HzlaiXnBiivAHT4sevVRKPpwCoPF3hayX7wOnt4tzaPyfH39T6ABaZ
ir51m5k7cTlUJsCGgQzpViJHs9RBFjqJaggAFUj1LrdRQZFyNZF6NfSwyjD1OX6f
rruZvKAoRhHCxJ1bBbmOV1rSouGxvZ6cU3zYbGWtMVPOXh6ZsJ+z6JV9zf2m+fl9
CYUBDANgLY4AylGsfwElAlufKErQwRAPBz8h6Fhig8MyfMgXnC0kNJqVgVvdXNGv
WBqg847JAenPjlEVKGugMRrHHF+3vPB3H1tMbq5Nle7Teig1ffN7pMl+7ubhGekj
JcJsPAuo6gl5lDBd/lPOdfC/PQp7L5o0cbwBDfgAfoajaxgVkNo7kZcPshqaRzkU
yL3Pe/XDy2LTTz5E0N+EOKul6WXLaOao8c5gSOcMDovsuXe8GO8G/QhZK1FaD5r8
hlwsi3XZrXHGyrUTldewlz4Y3u9ty7/X+pz+qGbO0dKimJeAbBKJoBENAGLI+gQx
9zb9ssuzVkOtO9CPueXa0ZQUemolw1EFO4qSYJJBrnbSwMUBq0Kd4y/cx9JVFqZP
4kaktOE3nO4GBW7ju6Zt/OV7W/fx0ts7+WEdgKlDcQwqGPhj4UmKd808dkNc46fQ
4KMLjpK94vAAkpVQHFrrZyCjnjACi7t6EBNXHXrbJDzozJaJ5y4hlgoirdyVtpAz
oJUl2JW0sRi0ss+nz9rX9z+3n8SJ9hE7ChNFUp5gdWNiC0Z3OPr8gTlgtDOdsE9o
Ar9p6dWQyvlbv8hyg5twcWqzxWZlQZn5H3t0ljk9Ci2NLkNzqYsJGF0ygN/GUvWB
E35VagUT0jOl23h/eVz+iAHugDX25CeUR40aagFOh3N7TSOJQ9DK8KDX807LOhg8
iBMNNQGBgrfbShFIlWAzoCBhlqTF0pUrLqyP4WYuXOsU+N51dyN6NYe+L+nhD0XF
XoXKgX6vt8D+GFxq1XYRfA4+MF0SciA3+nnF8QKztfz2l7pE0O1gAbZiM0TDm2SA
Rs9yNLwFlJxqigXX4fHlcre3ZyCs4YE64KjfcUMF919tSftWhlnshg==
=JMLY
-----END PGP MESSAGE-----

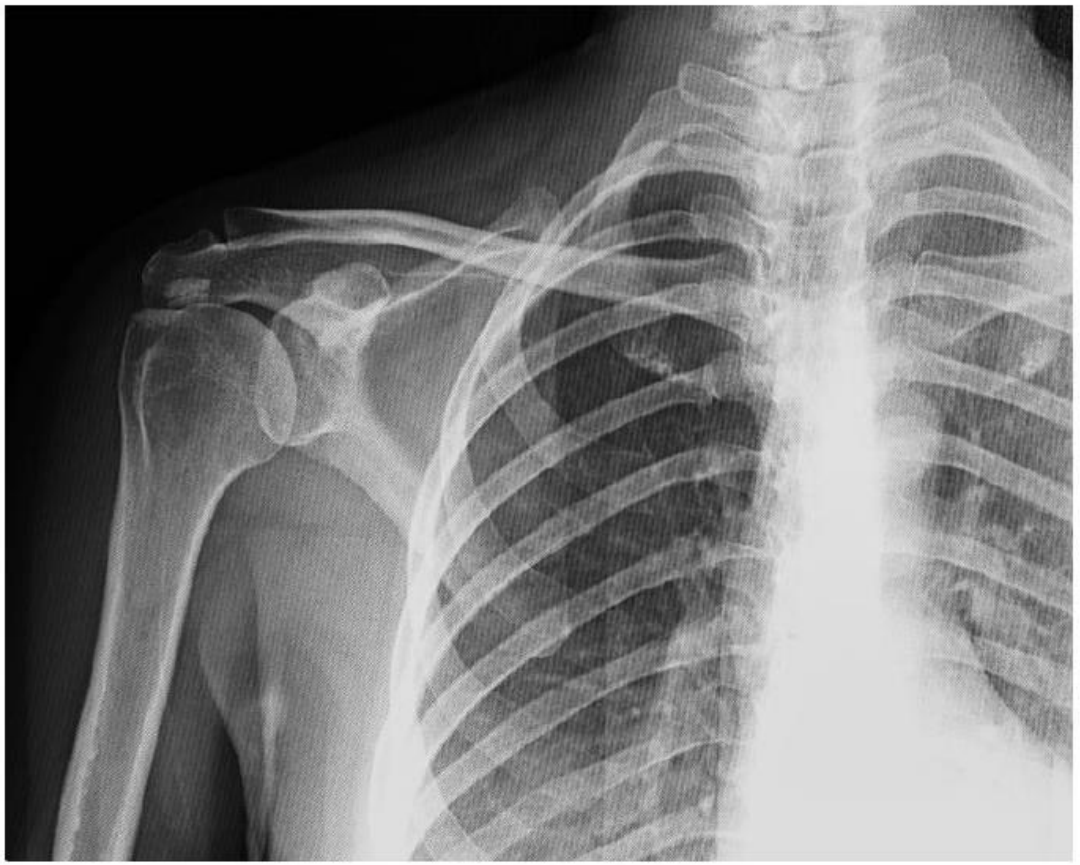


Implementación de la Confidencialidad.
Correo Electrónico. OpenPGP

- Descifrado

PRUEBA 3
Seguridad: Cifrado, Firmado (@gmail.com), 1 cifrado/firmado adjunto 2

Archivo adjuntado: .jpg



Aspectos Legales de la Confidencialidad.

- Constitución Española:
  - Artículo 18 se establece las garantías para el honor y la intimidad donde se garantiza el secreto de las comunicaciones y, en especial, de las postales, telegráficas y telefónicas, salvo resolución judicial" , y además "la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos".
- Código Penal Español:
  - "*Artículo 197. 1. El que, para descubrir los secretos o vulnerar la intimidad de otro, sin su consentimiento, se apodere de sus papeles, cartas, mensajes de* ***correo electrónico*** *o cualesquiera otros documentos o efectos personales, intercepte sus telecomunicaciones o utilice artificios técnicos de escucha, transmisión, grabación o reproducción del sonido o de la imagen, o de cualquier otra señal de comunicación, será castigado con las penas de prisión de uno a cuatro años y multa de doce a veinticuatro meses.*"

Implementación de la Confidencialidad.
Correo Electrónico. S/MIME

- Otro protocolo es S/MIME (Secure MIME)
  - Soportado por la mayor parte de los clientes de correo
  - Autenticación, Integridad del mensaje, No repudio del emisor (usando firma digital), Confidencialidad (usando cifrado)
- Protocolo definido en RFC 2632-2643.
- Está pensado como la versión industrial y seria de PGP, pensado para organizaciones (gran número de usuarios)
- Utiliza **envoltorio digital,** basado en tipo especial MIME llamado **PKCS (*Public Key Cryptography Standard*),** que permite dentro del mensaje autenticar, cifrar y firmar partes de éste, según las opciones.
- Utiliza certificados X.509v3 y redes de confianza.
- Utiliza SHA-1 y MD5 para compendios y en las firmas utiliza RSA
- Cifrado de mensajes: con claves de sesión simétricas.

- Problemas
  - Determinados gobiernos restringen la exportación de la tecnología PGP y por tanto el uso de las mismas para el envio de correo.
  - Algunos protocolos no autentican con certificados
  - Algunos usan las versiones más antiguas de ***RSA***
  - Articulo sobre experto en criptografía titulado "**PGP encryption is broken, Time for PGP to Die**"
    - http://thehackernews.com/2014/08/cryptography-expert-pgp-encryption-is_19.html
  - Código Malicioso en correos, posible solución integrar Clam-AV

Implementación de la Confidencialidad.
Analizadores de Protocolos de Red

- WireShark (conocida desde hace años ***Ethereal)*** *para* sniffing y recogida de datos sobre una red.



  - Es el estandar *de facto* (y frecuentemente *de jure*)
  - WireShark ha aumentado sus capacidades con el soporte de varios tipos de redes (Ethernet, 802.11, etc.) y también en la simplicidad de uso a través de interfaces amigables de usuarios.
  - Permite a los ***CISO*** demostrar que protocolos anticuados tales como ***Telnet / FTP deben ser excluidos*** de la red corporativa, y que la información sensible debe ser cifrada.
  - Una estrategia para ***validar políticas de filtrado de red*** cuando se coloca cerca de los dispositivos de filtrado.

http://www.inteco.es/CERT/guias_estudios/guias/guia_wireshark

Bibliografía y webgrafía

- SSL
  - **Implementing SSL / TLS Using Cryptography and PKI (Google eBook) 2011** Joshua Davies
  - **TLS v 1.0 RFC - http://www.ietf.org/rfc/rfc2246.tx.**
  - **SSL-v3** http://www.netscape.com/eng/ssl3/draft302.txt
- SSH: The Definitive Guide
  - http://www.snailbook.com/
- Analizadores de protocolos de red
  - http://www.wireshark.org/